Account Security Policy

Document owner: Information Security Office | Version 4.1 | Last reviewed: January 2026

URL: https://portal.company.com/security/account-policy

1 Purpose and Scope

This policy describes how Acme Corp employees and customers create, protect and recover their accounts. It applies to the employee single sign-on (SSO) account, the customer portal account at app.company.com, and every system that uses them. Security questions can be sent to security@company.com.

2 Password Requirements

2.1 Password Rules

Passwords must be at least 14 characters long and contain at least three of the following: uppercase letters, lowercase letters, numbers and symbols. Passwords must not contain your name, username or the word "Acme". The last 10 passwords cannot be reused. Using a passphrase of four or more random words is recommended.

2.2 Password Expiry

Employee passwords expire every 180 days; you will receive reminder emails 14, 7 and 1 day before expiry. Customer passwords do not expire, but customers are asked to change them if a breach is suspected.

2.3 Password Managers

Employees should store passwords in the approved password manager, 1Password Business, which is installed on every company laptop. Passwords must never be stored in browsers on shared devices, in spreadsheets or on paper.

3 Resetting Your Password

3.1 Customer Password Reset

To reset your password, go to the Login Page at app.company.com/login and select "Forgot Password". Enter the email address registered to your account. You will receive a password reset link at your registered email; the link is valid for 30 minutes and can be used once. If you don't receive it within 5 minutes, check your spam or junk folder, confirm you used the email address registered to the account, or contact support at support@company.com or through the in-app chat.

3.2 Employee Password Reset

Employees reset their SSO password through the self-service portal at password.company.com. Select "Reset password", enter your work email and approve the verification request in your authenticator app. If you cannot access your authenticator app, call the IT Service Desk on extension 4357 (HELP) or +1 555 010 4357; the agent will verify your identity with your employee ID and manager's name before issuing a temporary password.

3.3 Account Lockout

After 5 failed login attempts an account is locked for 15 minutes. It unlocks automatically after that time. If you are locked out repeatedly, contact the IT Service Desk, as this may indicate that someone else is trying to access your account.

4 Two-Factor Authentication (2FA)

4.1 Who Must Use 2FA

Two-factor authentication (also called multi-factor authentication or MFA) is mandatory for all employee accounts and for customer accounts with administrator rights. It is strongly recommended for all other customer accounts.

4.2 Setting Up 2FA

For employees, 2FA is set up on the first day using Microsoft Authenticator: go to mysecurity.company.com, sign in, select "Add sign-in method" > "Authenticator app" and scan the QR code. Customers enable 2FA in app.company.com under Settings > Security > Two-Factor Authentication, and can use any TOTP authenticator app (Google Authenticator, Microsoft Authenticator, Authy) or SMS codes.

4.3 Updating 2FA Settings

To update your 2FA settings, for example after getting a new phone, sign in and open mysecurity.company.com (employees) or Settings > Security (customers). Add the new device first, confirm it works, and only then remove the old device. Always keep at least two sign-in methods registered, such as the authenticator app plus a phone number.

4.4 Lost or Stolen Phone

If the phone with your authenticator app is lost or stolen, report it immediately to the IT Service Desk (employees) or support@company.com (customers). Your existing 2FA methods will be revoked and you will be given a one-time bypass code valid for 24 hours to register a new device. Customers who saved backup codes during setup can use one of them to sign in.

4.5 Backup Codes

When 2FA is enabled, ten single-use backup codes are generated. Store them in your password manager. New codes can be generated at any time from the security settings page, which invalidates the old ones.

5 Phishing and Suspicious Activity

5.1 Reporting Phishing

Report suspicious emails using the "Report Phishing" button in Outlook, or forward them as an attachment to phishing@company.com. Do not click links or open attachments in a suspicious message. The Security Operations Centre reviews every report within 4 business hours.

5.2 Compromised Accounts

If you believe your account has been compromised, change your password immediately and contact the IT Service Desk (employees) or support@company.com (customers). Employee incidents are treated as priority 1 and are handled 24/7.

6 Access Management

6.1 Shared Accounts

Sharing account credentials is prohibited. Teams that need shared access must request a service account through the IT Service Portal with a named owner.

6.2 Access Reviews

Managers review their team's system access every quarter. Access that is no longer needed is removed within 5 working days.

6.3 Leavers

Access for employees who leave the company is disabled at 18:00 on their last working day.